

Teoria R2 — Autenticació, autorització i operació protegida

Preparació per a R2M5: registre, hash de contrasenya, login i operació protegida en PHP.



Tres conceptes fonamentals



Identificació

L'usuari diu qui és (nom, email...)



Autenticació

El sistema comprova que és qui diu ser



Autorització

El sistema decideix què pot fer



Autenticació i autorització són conceptes **diferents**. No confondre'ls.

Registre: guardar la contrasenya amb seguretat

Les contrasenyes **mai** es guarden en text clar. Usem `password_hash()` per generar un hash segur i irreversible que es desa a la base de dades.

 El hash és unidireccional: no es pot recuperar la contrasenya original a partir del hash.

```
// Registre mínim
$hash = password_hash(
    $password,
    PASSWORD_DEFAULT
);

// Desar $hash a la BBDD
// Mai desar $password directament
```

Login: verificar la contrasenya

Durant el login, recuperem el hash de la BBDD i el comparem amb la contrasenya introduïda usant `password_verify()`. Si coincideix, guardem a sessió només l'identificador mínim de l'usuari.

- ✓ Guardar el mínim en sessió: només l'id, mai la contrasenya ni dades sensibles.

```
if (password_verify(  
    $password,  
    $usuari['password_hash']  
) {  
    session_regenerate_id(true);  
    $_SESSION['user_id'] = $usuari['id'];  
}
```



La protecció ha d'estar al servidor

✗ Ocultar un botó

Amagar un element HTML **no protegeix** l'operació. Qualsevol pot enviar la petició directament.

✓ Comprovar al servidor

Cada petició ha de verificar l'autenticació **abans** d'executar qualsevol lògica sensible.

Funció de protecció d'accés

Creem una funció reutilitzable que es crida al principi de qualsevol pàgina o endpoint protegit. Si l'usuari no està autenticat, retorna un 403 i atura l'execució immediatament.

- ⊗ Cal cridar aquesta comprovació **abans** de mostrar dades o executar qualsevol operació.

```
function requereixLogin(): void {  
    if (!isset($_SESSION['user_id'])) {  
        http_response_code(403);  
        exit('Accés denegat');  
    }  
}
```

```
// Al principi de cada operació:  
requereixLogin();
```

Operació protegida real

Una operació protegida ha de tindre **valor real dins del producte**: eliminar un element, editar dades pròpies, accedir a un panell privat...

```
// Exemple: eliminar un article propi
requireLogin();

$id = (int) $_POST['id'];
// Verificar que l'article pertany a l'usuari autenticat
$stmt = $pdo->prepare(
    'DELETE FROM articles WHERE id = ? AND user_id = ?'
);
$stmt->execute([$id, $_SESSION['user_id']]);
```

❏ No protegir una pàgina d'exemple sense valor real no demostra comprensió del concepte.

Logout correcte

```
// Logout complet
session_start();
$_SESSION = [];
session_destroy();

// Redirigir a la pàgina d'inici
header('Location: /index.php');
exit;
```

Per fer un logout correcte cal:

1. Buidar totes les variables de sessió
2. Destruir la sessió amb `session_destroy()`
3. Redirigir l'usuari fora de la zona privada



No n'hi ha prou de tancar la finestra del navegador.

Casos de prova obligatoris

1

Cas permès

Login correcte → accés a l'operació protegida → resultat esperat.

2

Cas denegat

Sense login → petició directa a l'endpoint → resposta 403 i sense execució.

3

Logout

Després del logout → intent d'accés → redirecció o 403 correctament.

Documentar cada prova amb captura o registre de la resposta HTTP obtinguda.

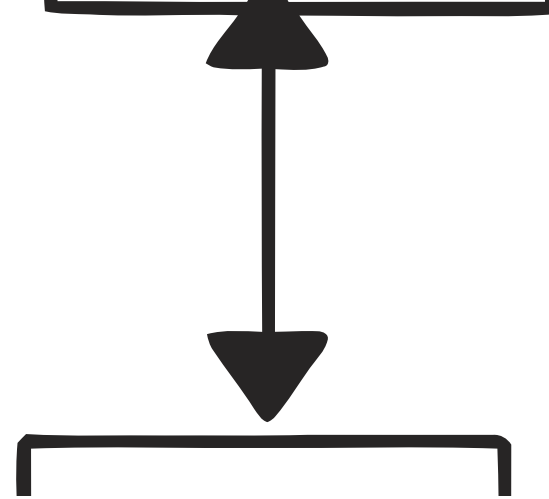
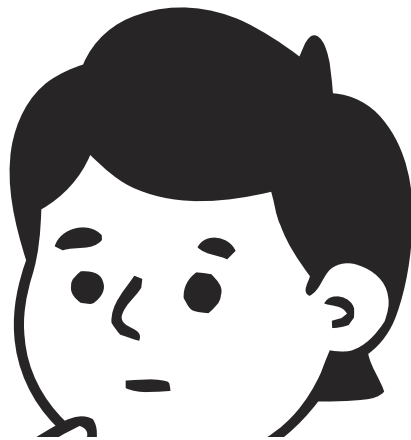
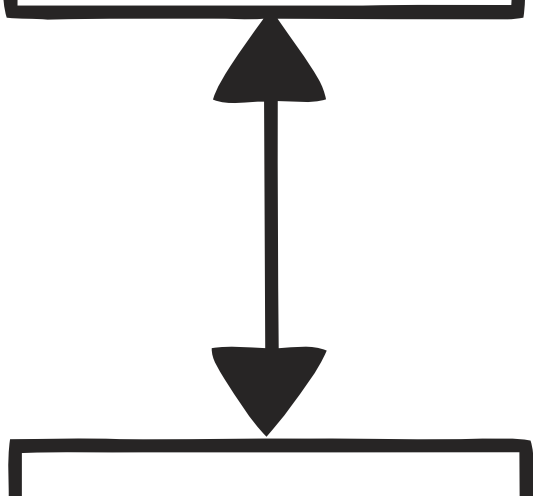
Errors habituals i checklist final

Errors habituals

- Guardar la contrasenya en text clar a la BBDD
- Protegir només amb CSS o JavaScript (ocultar botons)
- Guardar dades sensibles a `$_SESSION`
- No cridar `requereixLogin()` a tots els endpoints
- Logout incomplet: no destruir la sessió

Checklist R2

- ☒ Registre amb `password_hash()`
- ☐ Login amb `password_verify()`
- ☐ Sessió amb identificador mínim
- ☐ Funció `requereixLogin()` o equivalent
- ☐ Operació protegida amb valor real
- ☐ Logout amb `session_destroy()`
- ☐ Prova cas permès, denegat i logout



Preguntes de comprovació

- Quina diferència hi ha entre **autenticar i autoritzar**? Defineix amb claredat ambdós conceptes i per què són crucials en seguretat.
- On es guarda el hash i on es comprova la contrasenya?
- Quina operació real del teu projecte queda protegida?
- Què passa si una persona no autenticada intenta executar-la?
- Com demostres logout o invalidació de sessió?